VEHICLE PARKING SYSTEM

SECURITY LOG

Course	Software Engineering | UE23CS341A, PES University, Department of CSE (Security Design and Architecture, Unit 2, Lectures 2-3)
Repository	github.com/Sam-0960/Vehicle-Parking-System---SE---D-sec
Version	0.3 (15-Oct-2026). Restructured into the SRS table format and cross-referenced to the SRS (FR-01 to FR-14, NFR-01 to NFR-08).
Purpose	To identify security risks, suggest safeguards and record what still needs to be checked.
Status terms	**Proposed**: suggested control, not confirmed. **Implemented**: present in code/config with evidence (commit, PR, screenshot). **Verified**: implemented and tested, with test evidence recorded.
Note	This is a working record. Risks and controls are proposals, and tests are not run, unless evidence is added. Likelihood (L) and impact (I) are rated Low=1, Medium=2, High=3; score 1-2 Low, 3-4 Medium, 6 High, 9 Critical. They are initial estimates, not measured results.

1. SECURITY OBJECTIVES

Obj ID	Objective	Description	Priority
SO-01	Confidentiality	The system shall allow only authorised users to view user profiles, vehicle numbers, parking history and payment-related information. (SRS: FR-01, FR-02, FR-10, NFR-02)	High
SO-02	Integrity	Reservation details, slot status, parking fees and payment records shall change only through approved actions, and a slot shall never be assigned to multiple vehicles at the same time. (SRS: FR-03, FR-08, NFR-03, NFR-08)	High
SO-03	Replay Protection	Re-sending an old reservation or payment request shall not create a duplicate reservation or charge. (SRS: FR-07, FR-09)	High
SO-04	Availability	Reservation and vehicle entry/exit functions shall remain usable during heavy traffic or repeated abusive requests. (SRS: FR-05, FR-06, NFR-05)	High
SO-05	Accountability	Important actions such as logins, role changes, refunds and manual slot changes shall be recorded so they can be traced. (SRS: FR-12, NFR-02)	Medium

2. ASSETS AND DATA FLOW

Asset ID	Asset	Description	Priority
A-01	User Credentials and Profile	Entered at registration/login (FR-01). Travels client to server, is stored in the user table and is used for login and profile view.	High
A-02	Vehicle and Reservation Data	Entered through vehicle registration and reservation forms (FR-02, FR-07). Travels client to app and app to database, is stored in the reservation table and is used for slot display and verification.	High
A-03	Payment and Billing Records	Created at payment or exit (FR-08, FR-09). Travels app to payment gateway (assumed), is stored as billing records (card data is not planned to be stored) and is used for receipts and reports.	High

Asset ID	Asset	Description	Priority
A-04	Slot Inventory and Rates	Set from the admin dashboard (FR-03, NFR-07). Travels admin client to server, is stored in slot and tariff tables and is used for availability and fee calculation.	High
A-05	Admin Accounts and Audit Logs	Created at admin setup and by system events. Travels app to log store, is kept in log files or a table and is used for security review.	Medium

3. TRUST BOUNDARIES

TB ID	Boundary	Description	Priority
TB-01	Customer Data Isolation	Customers shall be able to access only their own information.	High
TB-02	Role Separation	Users and parking administrators (the roles defined in FR-01) shall use only the functions allowed for their role. Anonymous visitors and unauthenticated API callers shall not access protected data. An attendant role is not in the SRS; add it here only if the team adds it.	High
TB-03	Payment Gateway	A payment gateway response shall be trusted only after it has been verified.	High
TB-04	Architecture Boundaries	The architecture shall show the boundaries between browser and application server, application server and database, application server and payment gateway, and admin interface and application server.	Medium

4. RISK REGISTER

Risk ID	Risk	Description	Priority
R-01	Weak or Stolen Credentials	Passwords may be guessed or stolen, or pages opened without logging in. Area: login/authentication (FR-01). L: Medium, I: High. Controls: C-01, C-07.	High
R-02	SQL Injection	Malicious text in login, search or vehicle-number fields may interfere with database queries. Area: database, login, vehicle search (FR-13). L: Medium, I: High. Controls: C-03, C-10.	High
R-03	Customer Gains Staff/Admin Access	A customer may reach administrator functions (FR-03, FR-12, FR-14) by changing a URL or request. Area: authorisation/admin area. L: Medium, I: High. Controls: C-02.	High
R-04	Personal or Vehicle Data Leaks	Data may appear in errors, logs, unencrypted traffic, notifications (FR-11), reports (FR-14) or overly broad API responses. Area: API, logs, database, network. L: Medium, I: High. Controls: C-04, C-09, C-10.	High
R-05	Reservation Changes or Double Booking	Another user's reservation, price or time may be changed, or one slot booked twice (conflicts with NFR-08). Area: reservation and slot inventory (FR-05, FR-07). L: High, I: Medium. Controls: C-02, C-05.	High
R-06	Payment Tampering or Replay	The amount may be changed, a payment request replayed, a gateway response forged or card details stored unsafely. Area: payment integration (FR-09). L: Medium, I: High. Controls: C-04, C-06.	High
R-07	Session Hijacking / Request Replay	A stolen session token or captured request may be reused. Area: session handling. L: Medium, I: Medium. Controls: C-01, C-04.	Medium

Risk ID	Risk	Description	Priority
R-08	API Abuse or Slot Hoarding	Many requests, or unpaid reservations, may be used to hold slots. Area: reservation endpoints. L: Medium, I: Medium. Controls: C-07.	Medium
R-09	Unsafe Defaults or Configuration	Debug mode, default credentials or secrets in source code may be exposed. Area: deployment/admin settings. L: Low, I: High. Controls: C-08.	Medium
R-10	Staff/Admin Misuse	An insider may misuse admin, database or log access. Area: admin area, database, logs. L: Low, I: High. Controls: C-02, C-09, C-10.	Medium
R-11	Missing Security Logs	Attacks may go unnoticed or untraceable. Area: logging and monitoring. L: Medium, I: Medium. Controls: C-09.	Medium

5. SECURITY CONTROLS

Priority follows the highest-rated linked risk. Every control stays Proposed until there is evidence of implementation, and becomes Verified only after its related test passes.

Control ID	Control	Description	Priority
C-01	Login Security	The system shall enforce a password policy, bcrypt/Argon2 password hashing, login lockout, session expiry and rotation, and MFA for administrators. Mitigates R-01, R-07. Status: Proposed.	High
C-02	Role-Based Access Control	The system shall check permissions on the server for every request, deny access by default, and separate user and administrator permissions. Mitigates R-03, R-05, R-10. Status: Proposed.	High
C-03	Input Validation	The system shall validate inputs and use parameterised database queries instead of building SQL from strings. Mitigates R-02. Status: Proposed.	High
C-04	Transport and Data Protection	The system shall use TLS for client and gateway traffic, protect sensitive stored data, return only necessary fields, avoid detailed error messages, and use mTLS if services are separated. Mitigates R-04, R-06, R-07. Status: Proposed.	High
C-05	Reservation Integrity	The system shall check reservation ownership, use unpredictable IDs, lock slots within transactions and calculate fees and times on the server. Mitigates R-05. Status: Proposed.	High
C-06	Payment Safety	The system shall use a hosted payment gateway or tokenisation, never store card numbers or CVV, verify gateway callbacks and prevent duplicate processing. Mitigates R-06. Status: Proposed.	High
C-07	Rate Limiting	The system shall rate-limit login, reservation and payment APIs and expire temporary slot holds. Mitigates R-01, R-08. Status: Proposed.	High
C-08	Secure Configuration	Debug mode shall be disabled, default credentials removed, secrets stored outside source code and only necessary ports exposed. Mitigates R-09. Status: Proposed.	Medium
C-09	Security Logging	The system shall log logins, role changes, refunds and slot overrides, shall not log passwords or payment data, and shall restrict log access. Mitigates R-04, R-10, R-11. Status: Proposed.	High

Control ID	Control	Description	Priority
C-10	Database Isolation	The database shall be inaccessible directly from clients and shall be used through an account with limited permissions. Mitigates R-02, R-04, R-10. Status: Proposed.	High

5.1 ARCHITECTURE REVIEW

Review ID	Question	Description	Status
AR-01	Separation	Are sensitive components separated? Add evidence explaining database, payment and admin separation.	Yes / Partial / No
AR-02	API Protection	Are APIs authenticated, rate-limited and validated? List the endpoints reviewed.	Yes / Partial / No
AR-03	Encryption	Is encryption used in transit and at rest where needed? Add TLS and storage configuration evidence.	Yes / Partial / No
AR-04	Defaults	Are default settings secure? Add a configuration review reference.	Yes / Partial / No

6. SECURITY TESTING CHECKLIST

No test below has been run in this draft. Record the result and attach evidence only after carrying out each test.

Test ID	Test	Description	Priority
T-01	Repeated Wrong Password	Enter an incorrect password repeatedly. Expected: generic error, throttling or lockout works and attempts are logged. Risk: R-01. Result: Not executed.	High
T-02	Unauthenticated Access	Open a protected page or API without logging in. Expected: redirect to login or 401, with no protected data returned. Risk: R-01. Result: Not executed.	High
T-03	SQL Injection	Enter SQL-like input in login, search and vehicle-number fields. Expected: input is treated as text or rejected, with no database error or data change. Risk: R-02. Result: Not executed.	High
T-04	Privilege Escalation	Use a user account to open an administrator URL or API. Expected: access denied (403) and the attempt logged where supported. Risk: R-03. Result: Not executed.	High
T-05	Object-Level Access	Change a reservation or user ID in a request to reach someone else's data. Expected: access denied and no other user's data returned. Risk: R-04, R-05. Result: Not executed.	High
T-06	Payment Tampering	Change the amount or duration in a payment request. Expected: server recalculates the fee and rejects tampered values. Risk: R-06. Result: Not executed.	High
T-07	Request Replay	Resend a reservation or payment request. Expected: duplicate processing prevented, with no second reservation or charge. Risk: R-06, R-07. Result: Not executed.	High

Test ID	Test	Description	Priority
T-08	Concurrent Booking	Have two users try to reserve the same slot at once. Expected: only one succeeds and the other gets a clear conflict message. Risk: R-05. Result: Not executed.	High
T-09	Plain HTTP	Try plain HTTP and inspect traffic. Expected: traffic uses TLS and HTTP redirects to HTTPS. Risk: R-04. Result: Not executed.	High
T-10	Error Handling	Send malformed input to trigger an error. Expected: generic error, with no stack trace or SQL details. Risk: R-04, R-09. Result: Not executed.	High
T-11	Stored Data	Check stored credentials and payment data. Expected: passwords are hashed and card number and CVV are not stored. Risk: R-04, R-06. Result: Not executed.	High
T-12	Session Reuse	Log out, then reuse the old session token and inspect cookie flags. Expected: old token invalid and cookies use Secure and HttpOnly where applicable. Risk: R-07. Result: Not executed.	Medium
T-13	Request Flooding	Send many requests to login and reservation APIs. Expected: rate limit applied and service stays responsive. Risk: R-08. Result: Not executed.	Medium
T-14	Log Review	Review logs after the above tests. Expected: relevant authentication, admin and payment events appear and secrets are absent. Risk: R-11, R-04. Result: Not executed.	High
T-15	Defaults and Debug	Check for default accounts and debug mode. Expected: no default credentials and debug mode disabled in deployment. Risk: R-09. Result: Not executed.	Medium

7. SECURITY EVENT LOG

Record an entry when a security issue, failed test, suspicious activity, vulnerable dependency or configuration problem is found, with the date and evidence. No security incident has been reported in this draft.

Log ID	Event	Description	Severity
SEC-001	Log Created	14-Oct-2026. Created the initial security log and risk register from course notes. Shared for team review. Status: closed. Evidence: v0.2.	Informational
SEC-002	SRS Cross-Check	15-Oct-2026. Risk register compared with the SRS in v0.3. Findings: the SRS defines only users and parking administrators (no attendant role); FR-09 does not name a payment gateway; FR-11, FR-13 and FR-14 were added to the affected areas; NFR-02 is the only security requirement and is generic. Status: open until the team confirms. Evidence: commit/document reference to be added.	Informational
SEC-003	To be added	YYYY-MM-DD. Event description. Action taken, open/closed. Evidence: screenshot, log or issue link.	Severity
SEC-004	To be added	YYYY-MM-DD. Event description. Action taken, open/closed. Evidence: screenshot, log or issue link.	Severity

8. INCIDENT RESPONSE

IR ID	Severity Level	Description	Priority
IR-01	Critical	Example: confirmed data breach, payment fraud or admin account takeover. Response: contain immediately and notify the faculty/stakeholders.	Critical
IR-02	High	Example: successful SQL injection or privilege escalation. Response: contain the issue and begin fixing it the same day.	High
IR-03	Medium	Example: repeated failed logins, rate-limit bypass or configuration issue. Response: plan and complete the fix in the current sprint.	Medium
IR-04	Low	Example: minor information disclosure or a missing security header. Response: add the fix to the backlog.	Low

Step ID	Step	Description	Order
RS-01	Detect and Report	Record the event, date and evidence in the Security Event Log.	1
RS-02	Assess	Decide the severity and identify the affected component and data.	2
RS-03	Contain	Disable the affected account, endpoint or feature if needed. Revoke sessions or keys and preserve logs and screenshots.	3
RS-04	Fix	Correct the code or configuration issue and raise a change request for any design gap.	4
RS-05	Recover	Restore normal service and rerun the relevant test.	5
RS-06	Review	Record lessons learned and update the risk register.	6

Role ID	Role	Responsibility	Assigned To
RO-01	Incident Lead	Coordinates the response and decisions.	[Name]
RO-02	Technical Owner	Investigates and applies the fix.	[Name]
RO-03	Log Keeper	Maintains the log and evidence.	[Name]
RO-04	Faculty Contact	Informed about High and Critical events.	[Name]

9. CONCLUSION

At the time of writing, all controls are Proposed, no tests have been executed and no incidents have been recorded. Next steps: confirm the SRS cross-check (SEC-002), prioritise the High-rated risks R-01 to R-06, implement the agreed controls, attach evidence and update the checklist as tests are completed.

Reference: Software Engineering, Unit 2 Lecture 2-3, Security Design and Architecture, Department of CSE, PES University (UE23CS341A).